

目录

一、 引言	2
二、 背景与威胁模型	2
2.1 物联网体系结构与攻击面	2
2.2 本文讨论范围	3
2.3 攻击链、资产状态与安全目标	3
2.4 数据与标签的可信性	4
三、 AI 赋能物联网安全的分类框架	4
3.1 模型在安全闭环中的分层角色	5
3.2 证据链与不确定性传播	6
3.3 大模型自身的新增攻击面	6
四、 代表性研究综述	6
4.1 固件与协议漏洞挖掘	6
4.2 流量与日志入侵检测	7
4.3 Bot-IoT 数据集与轻量顺序检测	8
4.4 设备识别与威胁情报	8
4.5 安全智能体与自动化响应	9
4.6 小结：现有工作的共性问题	9
五、 实验评估	9
5.1 数据集与实验设置	10
5.2 对比方法	11
5.3 结果与分析	12
5.4 公开论文结果对照	13
5.5 Bot-IoT 与顺序检测的详细结果	14
5.6 跨论文结果的统一解释	15
六、 综合讨论与工程建议	15
6.1 从离线指标到线上服务等级	15
6.2 模型选择的决策矩阵	16
6.3 如何把大模型纳入可验证闭环	17

6.4 复现与论文写作清单	17
七、挑战与展望	17
八、结论	18
A 复现实验记录模板	19
参考文献	21

大模型赋能物联网安全：研究综述与实验评估

课程名称：物联网安全

姓名：徐诗霖 学号：202622080929

摘要

物联网设备具有规模大、软硬件异构、资源受限和长期在线等特征，安全事件往往表现为弱信号、多阶段和跨层关联。传统规则和轻量检测器在低时延、高吞吐场景中仍不可替代，但面对设备基线漂移、加密流量、标签不均衡和未见攻击时容易出现误报与漏报。

本文围绕大模型赋能物联网安全，首先从感知层、网络层和应用层建立威胁模型，进一步构造“安全任务 × 人工智能范式”的二维分类框架，系统综述固件与协议漏洞挖掘、流量与日志入侵检测、设备识别、威胁情报和自动化响应等方向的代表性方法。在实验评估部分，本文提出面向 CICIoT2023 或 Edge-IIoTset 的可复现实验协议，统一比较随机森林、XGBoost、1D-CNN、无监督检测器与检索增强大模型，并明确按时间外推、按设备留出、宏平均 F1、误报成本和 P95 延迟等评价要求。为增强结论的可追溯性，本文整理 N-BaIoT、Kitsune、Bot-IoT、CICIoT2023 及顺序检测研究的公开结果：N-BaIoT 报告受感染设备 TPR 达 100%、平均 FPR 为 0.007 ± 0.01 ；Kitsune 在 Raspberry Pi 3B 上将集成规模从 $k = 1$ 扩展到 $k = 35$ 时，吞吐率约由 1000 包/秒提升至 5400 包/秒；Bot-IoT 和 CICIoT2023 的结果则显示，高 Accuracy 可能掩盖 Fall-out、类别不均衡和任务粒度带来的风险。

基于物理设备限制，本文不对文献的实验数据进行重新验证，主要工作是据此分析不同证据类型的适用边界。研究表明，大模型更适合承担异构证据融合、告警解释、跨时间线归因和受约束的响应编排，而不应直接替代边缘侧检测器或成为高风险操作的唯一依据；其工程落地仍受时延、隐私、幻觉、提示注入和对抗鲁棒性约束。最后，本文给出端—边—云协同与“建议—验证—执行”安全闭环，为物联网安全系统的设计、复现和评估提供参考。

关键字： 物联网安全 大语言模型 入侵检测 漏洞挖掘 端边云协同

一、引言

物联网（Internet of Things, IoT）把传感器、嵌入式控制器、网关、云平台和移动应用连接成一个跨域系统。与传统数据中心相比，IoT 设备通常采用低功耗处理器和实时操作系统，生命周期长且补丁窗口短；同一网络中还可能同时存在摄像头、路由器、工业控制器和可穿戴设备。NIST 将设备身份、数据保护、逻辑访问控制、软件更新和网络安全状态感知列为 IoT 设备的核心能力 [1]，ETSI EN 303 645 则进一步强调默认口令、漏洞披露和安全更新等基线要求 [2]。这些要求说明，IoT 安全不能只依赖某一个检测模型，而需要贯穿资产、通信、软件和运营流程的纵深防御。

现有防御系统大多由规则匹配、统计特征和监督学习模型组成。规则方法可解释、时延低，但对变种攻击和加密载荷不敏感；监督学习依赖稳定的标签分布，而 IoT 场景中设备更替和攻击迁移会导致明显的分布偏移。大语言模型（Large Language Model, LLM）具有跨模态文本推理、长上下文关联和工具调用能力，为日志解释、漏洞复核、威胁情报归并和响应编排提供了新接口，但其输出不应直接成为高风险自动化操作的唯一依据。

本文的主要工作包括三点：

1. 建立面向 IoT 的分层威胁模型，并将安全任务与 AI 范式映射到统一的二维框架；
2. 以“问题—代表方法—局限—工程评价”为主线，综述传统机器学习、深度学习和大模型方法的互补关系；
3. 设计一个可复现实验与端—边—云协同架构，明确数据划分、评价指标、消融变量和安全闸门，避免用未经验证的模型输出替代实证结果。

二、背景与威胁模型

2.1 物联网体系结构与攻击面

本文采用感知层、网络层和应用层的三层抽象。感知层包括传感器、执行器、摄像头和嵌入式固件，主要风险是调试接口暴露、弱口令、固件签名缺失、侧信道和物理篡改。网络层包括短距离无线、蜂窝网络、IPv6/6LoWPAN、MQTT、CoAP 和边缘网关，攻击者可实施重放、拒绝服务、路由欺骗、中间人攻击和流量伪装。应用层包括设备管

理平台、消息代理、数字孪生和移动端 API，主要风险是越权、供应链漏洞、租户隔离失败以及告警处置链条被滥用。

从攻击路径看，攻击者可能先通过默认凭据获得单个设备权限，再利用设备间的信任关系横向移动，最终以网关或云平台为跳板影响大规模设备。因而检测系统至少应同时维护三类状态：资产状态（设备是谁、运行什么固件）、行为状态（通信与操作是否偏离基线）以及证据状态（告警是否能由日志、流量和漏洞信息相互印证）。

2.2 本文讨论范围

本文聚焦防御侧的检测、分析和响应，不讨论密码算法的形式化证明，也不把 LLM 当作直接控制执行器。攻击样本以网络入侵、固件/协议缺陷、凭据滥用和异常行为为主；数据来源优先选择公开数据集与可脱敏日志。对于需要真实硬件或商业平台权限的部分，本文给出实验设计和风险控制，而不虚构现场结果。

2.3 攻击链、资产状态与安全目标

物联网攻击通常不是单一数据包或单一漏洞造成的结果，而是由侦察、初始访问、持久化、横向移动、控制与影响六个阶段组成。以 Mirai 类 botnet 为例，攻击者先扫描开放 Telnet 服务，再通过默认凭据完成初始访问，随后下载恶意样本、建立命令与控制连接，并利用感染设备发起扫描或洪泛攻击。若防御系统只在最后的 DDoS 阶段告警，就已经错过了最有价值的阻断窗口；反之，若能在凭据尝试、异常 DNS、固件变化和外连行为之间建立时间线，处置动作可以从“全网断开”降低为“隔离单设备并保留证据”。

因此，本文将安全目标分为四类。第一类是保密性，关注未授权读取、流量窃听和敏感遥测泄露；第二类是完整性，关注固件、配置、日志和控制命令是否被篡改；第三类是可用性，关注 DDoS、资源耗尽和关键设备失联；第四类是可追责性，要求告警、模型结论和执行动作都能回溯到具体证据。四类目标对应不同的评价重点：保密性更看重误报和数据暴露，完整性更看重证据链，可用性强调时延与吞吐量，可追责性则强调日志完整性和人工审批记录。

表 1 攻击阶段、可观测证据与防御目标

攻击阶段	典型行为	可观测证据	主要防御目标
侦察	端口扫描、主机发现、系统指纹识别	扫描频率、目的地址熵、失败连接比例	早期发现、降低资产暴露
初始访问	默认口令、弱认证、协议注入	登录失败、认证来源、异常命令序列	完整性、身份可信
持久化	固件植入、计划任务、配置篡改	文件哈希、启动项、固件版本差异	固件完整性、可追责
横向移动	网关跳转、异常内网连接、凭据复用	东西向流量、设备关系图、访问路径	最小权限、隔离传播
控制与影响	C2 通信、DDoS、数据外传	DNS/TLS 指纹、包速率、外传体量	可用性、保密性、快速止损

2.4 数据与标签的可信性

公开 IoT 数据集的价值不仅在于样本规模，还在于标签如何产生。pcap 级标签通常由攻击脚本的执行时间和抓包窗口推断；flow 级标签则依赖流提取工具将一段数据包映射到五元组；日志级标签还可能需要人工核对。不同标签机制会改变模型可学习的信号。例如，若同一攻击脚本生成的固定端口、固定时间间隔同时出现在训练集和测试集，模型可能只是记住脚本指纹，而不是学到可迁移的攻击行为。

本文对数据可信性的要求包括：记录采集拓扑、设备类型和攻击工具；记录训练/测试是否按时间、设备或攻击主体隔离；说明是否对流量进行随机打乱；同时报告类别分布、重复样本和缺失值处理。对于文献中只有随机划分的结果，本文将其视为“数据集可用性证据”，而不是“跨域部署性能”。这种区分也是后续报告结果解释的基本前提。

三、 AI 赋能物联网安全的分类框架

IoT 安全任务与 AI 技术不应按“是否使用大模型”二元划分。更有操作性的做法是从任务目标和模型角色两个维度建立分类，如表2所示。传统模型承担高频、低时延的判别；深度模型负责从原始序列中提取表征；大模型则聚合跨源证据、生成解释并调用受约束的工具。

下表2所示的框架隐含了一个重要原则：模型能力应与错误代价匹配。误报成本较低的资产盘点可以使用更开放的生成式模型；涉及断网、删证据或批量下发配置的响应动作，则应通过白名单、沙箱、最小权限和双人复核限制模型权限。LLM 的上下文窗口能够容纳较长的时间线，但上下文越长并不等于证据越充分，因此必须记录每条结论的来源、时间和置信度。

表 2 物联网安全任务与 AI 范式的二维分类

任务目标	传统机器学习	深度学习	大模型的适合角色
资产与设备识别	RF、XGBoost、聚类	自编码器、时序网络	根据指纹、配置和历史资产记录生成归一化画像
流量与日志检测	规则、统计检验	1D-CNN、LSTM、Transformer	对多源告警进行语义关联与解释，辅助未知攻击归因
漏洞挖掘	模糊测试、静态规则	图神经网络、代码模型	生成测试用例、总结补丁差异，结果须经工具复核
响应与运营	SOAR 规则	策略学习	生成处置剧本、查询威胁情报，关键动作需人工审批

3.1 模型在安全闭环中的分层角色

从工程角度看，AI 模型可被放置在感知、检测、分析和响应四个位置。感知层模型负责把原始数据压缩为稳定特征，例如流持续时间、包长统计、TLS 指纹和设备行为向量；检测层模型输出异常分数或攻击类别；分析层模型将多个告警和资产信息组织成时间线；响应层模型生成查询、隔离和取证建议。只有前两层适合追求固定时延和高吞吐，后两层更适合使用具有长上下文和工具调用能力的 LLM。

这种分层可以避免两个常见误区。第一个误区是把大模型直接放在数据包路径上，这会导致成本、隐私和时延不可控；第二个误区是只把 LLM 当作聊天界面，忽略其对资产查询、漏洞检索和处置编排的价值。合理系统应让边缘检测器输出结构化事件，例如设备哈希、窗口起止时间、协议、统计特征、规则命中和模型分数，再由云侧分析器进行跨事件推理。每个结论都应带有证据 ID，便于审计和人工复核。

3.2 证据链与不确定性传播

一个可审计的告警至少包含四个字段：观测事实、模型判断、外部知识和建议动作。观测事实是来自流量或日志的原始信息；模型判断是分类器或异常检测器的输出；外部知识包括 CVE、厂商公告和历史事件；建议动作则是隔离、采样、升级或人工确认。四类字段不可混写，否则分析人员难以区分“系统看到的事实”和“模型推断的解释”。

在不确定性传播方面，本文采用保守原则。若边缘模型给出低置信异常分数，云侧 LLM 不应把它改写为确定性攻击，而应提出补采证据；若检索库中存在相互冲突的漏洞信息，应保留冲突并降低结论等级；若工具调用失败，应返回“无法验证”而不是生成一个看似完整的替代结果。未来可以进一步使用校准曲线、保序回归和 conformal prediction，为异常分数增加可解释的置信区间。

3.3 大模型自身的新增攻击面

LLM 引入的风险不局限于传统模型的对抗样本。攻击者可以把提示注入写入设备名称、日志字段或威胁情报文本，使模型绕过系统指令；也可以伪造一个高相似度的 CVE 描述，诱导模型生成错误的修复建议。工具调用还可能出现参数污染，例如把“隔离单台设备”扩大为“隔离整个网段”。因此，LLM 安全应被纳入 IoT 威胁模型，而不是放在报告最后作为附加说明。

本文给出三道安全闸门：输入闸门对日志、情报和设备字段进行长度、字符集和来源校验；推理闸门强制模型使用结构化输出和证据引用；执行闸门对目标范围、权限、回滚和审批状态进行检查。三道闸门分别对应数据污染、幻觉解释和错误动作三个失败面，任何一道失败都应让系统降级为人工处置。

四、代表性研究综述

4.1 固件与协议漏洞挖掘

固件漏洞挖掘面对二进制格式不透明、架构多样和可执行路径难覆盖等问题。传统静态分析能够快速发现危险 API、硬编码口令和不安全配置，模糊测试则通过变异输入探索崩溃路径。对 MQTT、CoAP 等协议而言，状态机建模和语法感知变异比随机字节替换更有效。近年来，代码大模型被用于生成测试用例、解释反编译结果和总结补丁差异，但生成的代码可能不可编译、遗漏边界条件，甚至引入新的不安全逻辑。

本文认为, LLM 在该任务中最适合充当“分析助手”: 先由 Ghidra、Semgrep、AFL++ 或协议状态机工具产生可验证证据, 再由模型完成路径摘要、漏洞分类和修复建议; 漏洞是否成立仍需通过复现、静态规则和人工审阅三者至少一项确认。评价指标应包括真实漏洞命中率、重复报告率、每个样本的分析成本和修复建议可接受度, 而非只统计生成文本的流畅性。

4.2 流量与日志入侵检测

N-BaIoT 通过多层自编码器检测受 Mirai 感染的 IoT 设备行为 [3], Kitsune 则用在线无监督架构对网络流量进行实时异常检测 [4]。这类方法在已知数据分布上具有较低推理成本, 但跨设备、跨网络迁移时容易受到基线漂移影响。CICIoT2023 和 Edge-IIoTset 等数据集覆盖多类攻击, 为统一比较提供了基础 [5, 6]; 不过公开数据与真实生产环境在加密比例、设备更新频率和标签质量上仍有差异。

N-BaIoT 的实验具有较强的工程代表性: 研究者在隔离实验网络中部署了 9 台商用设备, 覆盖门铃、恒温器、婴儿监视器和摄像头等类型, 并使用真实的 Mirai 与 BASHLITE 感染流程产生攻击流量。模型输入为 115 个流量特征, 训练和阈值优化只使用正常数据, 测试集再加入扫描、UDP/TCP 洪泛等攻击。原论文报告所有受感染设备上的攻击 TPR 均达到 100%, 平均 FPR 为 0.007 ± 0.01 , 平均检测时间为 174 ± 212 ms[3]。该结果说明“设备专属正常行为建模”对 IoT 异常检测有效, 但也提示模型需要为每类设备建立基线, 不能简单假定所有设备共享同一分布。

大模型不适合直接逐包处理高吞吐流量, 更合理的方式是让边缘侧模型把窗口统计量、协议字段、时序摘要和历史告警压缩成结构化事件, 再由 LLM 执行跨窗口关联。例如, 同一设备在短时间内出现 DNS 异常、登录失败和固件配置变化时, 模型可以生成攻击时间线并提出需要补采的证据。此处应采用检索增强生成 (RAG) [7], 让模型只能引用当前资产库、规则库和经过签名的情报源, 降低无依据归因。

Kitsune 进一步验证了在线检测在边缘设备上的可部署性。其数据包含 OS 扫描、模糊测试、视频注入、ARP 中间人、主动窃听、SSDP 洪泛、SYN DoS、SSL 重协商和 Mirai 等攻击; 每个数据集的前 100 万个数据包用于训练, 剩余数据用于测试。作者以 FPR=0 和 FPR=0.001 下的 TPR/FNR、AUC 与 EER 评价检测能力, 并与 Isolation Forest、GMM、增量 GMM、pcStream 和 Suricata 比较。论文结论是, Kitsune 在多数数据集上的 AUC/EER 优于在线基线, 部分场景可达到或超过离线 GMM; 在 Raspberry Pi 3B 单核环境中, 将

集成层规模从 $k = 1$ 调整到 $k = 35$ 后，平均处理能力约从 1000 包/秒提升至 5400 包/秒 [4]。这一结果支持“边缘侧轻量检测 + 云侧语义分析”的分工，而不是让大模型承担逐包检测。

4.3 Bot-IoT 数据集与轻量顺序检测

Bot-IoT 研究从数据集建设角度补足了 N-BaIoT 和 Kitsune 的局限。该数据集在仿真与真实网络服务组成的测试床上生成正常流量、扫描、DDoS、DoS、信息窃取和键盘记录等攻击流量，原始数据超过 7200 万条记录，csv 版本约 16.7 GB，pcap 版本约 69.3 GB；作者同时提供了约 300 万条的可管理子集 [8]。通过相关系数和联合熵，论文筛选出 10 个高价值特征，并分别用 SVM、RNN 和 LSTM 进行二分类评估。全特征版本的 SVM 准确率为 0.999887，RNN 为 0.979061，LSTM 为 0.980573；10 特征版本的 SVM、RNN 和 LSTM 准确率分别为 0.883727、0.997405 和 0.997419。这个对比说明，特征压缩并不必然损害深度模型，但会明显影响不同模型的误报结构，因而不能只比较 Accuracy。

基于 N-BaIoT 的顺序检测研究进一步讨论了资源开销。该研究使用 849234 个样本，其中正常样本 17936 个、攻击样本 831298 个，包含 8 个攻击类别和 115 个流量特征；采用 66%/34% 的训练验证划分和 Min-Max 归一化。无特征选择时，J48 对 8 类攻击的逐类准确率约为 98.99%–99.09%，ANN 约为 98.95%–99.01%；使用特征选择后，NB 的逐类准确率提升到 97.34%–99.10%，而 J48 与 ANN 基本保持在 98.71%–99.10%。顺序混合分类器在个人电脑上处理 270908 个测试样本时，串行测试耗时 0.03 s，并行版本耗时 0.02 s，明显低于 ANN 的 9.71 s [9]。该实验为“边缘侧先筛选、云侧再解释”的架构提供了另一组量化依据。

4.4 设备识别与威胁情报

设备识别通常综合 MAC/OUI、DHCP、TLS 指纹、流量统计和行为序列。其难点是同型号设备指纹相似、固件升级会改变特征、虚拟化网关可能代表多个终端。传统分类器适合快速生成候选类别，LLM 则可将设备清单、厂商公告、CVE 描述和网络观测归并为可读的资产画像。威胁情报处理还需要解决实体消歧、过期指标和来源可信度问题，不能把一个域名或 IP 的历史命中直接等同于当前恶意行为。

建议为每条情报保留来源、发布时间、有效期、置信等级和冲突说明，并使用知识图谱或关系表保存“设备—固件—漏洞—通信对象”的关联。模型的输出应包含证据引用

和不确定性标签，例如“高置信：与已知漏洞版本一致；待确认：缺少固件版本证据”，从而便于分析人员复核。

4.5 安全智能体与自动化响应

安全智能体将检测、查询和处置串联成一个闭环。典型流程是：接收告警，查询资产与历史事件，调用沙箱或规则引擎验证，生成处置计划，执行低风险动作并等待高风险动作审批。大模型的工具调用能力可以减少 SOC 人员在多个系统间切换的成本，但也带来提示注入、越权调用和错误放大的风险。OWASP 对 LLM 应用提出了提示注入、数据泄露和不安全工具调用等风险类别 [10]，这些风险在 IoT 场景中会被批量设备规模进一步放大。

本文建议采用“建议—验证—执行”的三段式权限模型：模型只能提出结构化动作；验证器检查目标、范围、前置条件和回滚方案；执行器依据最小权限令牌完成动作并写入不可篡改审计日志。断网、批量升级和删除证据等操作必须由人工确认，且系统应提供一键回滚和离线应急通道。

4.6 小结：现有工作的共性问题

现有工作的共性问题可以归纳为四点。

第一，数据集多为单一网络或单一时间段采集，训练测试随机切分会高估模型对真实未知攻击的泛化能力。

第二，准确率常被作为主指标，忽略了类别不均衡、告警延迟和误报处置成本。

第三，模型解释停留在事后文字摘要，缺少与原始证据的逐项对齐。

第四，生成式模型的安全边界尚未被纳入系统级评估。后续实验应采用按时间和设备划分的数据、报告宏平均 F1 与每小时误报数，并把提示注入和工具权限作为攻击面进行测试。

五、实验评估

本节给出可复现实验方案。由于当前项目目录未提供真实采集数据、训练代码和硬件环境，本文不虚构实验数值；所有结果应在获得数据后按下述协议生成。

5.1 数据集与实验设置

CICIoT2023 适合评估大规模多攻击类型网络入侵检测，Edge-IIoTset 适合补充工业互联网、边缘节点和协议异构性。预处理阶段只使用训练集估计标准化参数；删除重复流、修复时间戳并保留设备 ID、协议、方向和窗口信息。数据划分采用“按时间外推 + 按设备留出”两种设置：前者检验概念漂移，后者检验新设备泛化。对于极少数攻击类别，使用类别权重而不是简单过采样，避免复制样本造成数据泄漏。

边缘检测以 5 s 或 10 s 为一个窗口，输出统计特征与候选告警；云端大模型只接收脱敏后的结构化事件，包括资产标识哈希、协议摘要、时间线、规则命中和检索到的漏洞信息。实验至少重复三次，报告均值和标准差，并固定随机种子、模型版本、提示模板和检索语料版本。

表 3 典型物联网安全数据集的规模与适用任务

数据集	年份	规模与采集方式	攻击覆盖	适合评估的问题
N-BaIoT	2018	9 台商用设备；115 个特征；849234 个样本（后续研究统计）	Mirai、BASHLITE；扫描、洪泛等	设备专属异常检测、botnet 早期发现
Kitsune	2018	摄像头监控网络与 9 台 IoT 设备；按数据包在线处理	OS 扫描、模糊测试、中间人、DoS、Mirai	在线检测、边缘吞吐率、低时延
Bot-IoT	2019	原始记录超过 7200 万条；csv 约 16.7 GB；pcap 约 69.3 GB	DDoS、DoS、扫描、信息窃取、键盘记录	大规模流量、特征选择、模型训练成本
CICIoT2023	2023	105 台设备；33 种攻击；pcap/csv 双格式	7 类攻击，包括 DDoS、Web、暴力破解和 Mirai	多分类、类别不平衡、设备与攻击泛化
Edge-IIoTset	2022	面向 IoT/IIoT 的集中式与联邦学习版本	网络、系统、应用和工业场景攻击	工业协议异构、联邦训练、跨节点泛化

为了避免随机切分造成数据泄漏，本文建议同时保留三种评估视角。第一种是论文复现实验视角，严格按照原论文的划分和预处理执行，用于验证实现是否正确；第二种是时间外推视角，用早期时间段训练、后期时间段测试，用于观察概念漂移；第三种是设备留出视角，将某些设备或厂商完全留在测试集，用于观察跨设备泛化。三种结果不能互相替代，必须在表格中分别标注。

```
1 # records: 流量级或窗口级的 IoT 事件记录
2 records = sanitize(records)
3
4 # 按时间外推划分：早期时段训练、后期时段测试，用于观察概念漂移
5 train, valid, test = split_by_time(records, ratios=(0.6, 0.2, 0.2))
```

```
6 # 设备留出：单独抽出未见设备，用于评估跨设备泛化
7 test_unseen = test[test.device_id.isin(held_out_devices)]
8
9 # 标准化参数只允许由训练集估计，再变换其余子集，避免信息泄漏
10 scaler.fit(train.features)
11 X_train = scaler.transform(train.features)
12 X_valid = scaler.transform(valid.features)
13 X_test = scaler.transform(test.features)
14
15 # 类别权重按频率反比设置，缓解攻击类别极不均衡（不做简单过采样）
16 model.fit(X_train, train.label, class_weight="balanced")
17
18 # 分别在验证集、测试集与留出设备集上报告宏平均指标
19 report(model, X_valid, valid.label, metrics=METRICS)
20 report(model, X_test, test.label, metrics=METRICS)
21 report(model, scaler.transform(test_unseen.features),
22         test_unseen.label, metrics=METRICS)
```

Listing 1: 按时间和设备留出的统一评估流程

5.2 对比方法

对比方法分为四组：

1. RF 与 XGBoost：作为低成本、可解释的传统基线；
2. 1D-CNN：直接处理窗口化流量特征，作为轻量深度模型；
3. 无监督自编码器：只用正常流量训练，用于未知攻击检测；
4. 检索增强 LLM：输入结构化告警和知识库，比较零样本、少样本以及“LLM 解释 + 规则执行”三种模式。

LLM 实验应固定温度、最大输出长度和工具白名单，并设置无检索、错误检索和提示注入三个对照组。这样可以区分模型本身的推理能力、外部知识贡献和安全防护机制的贡献。

为使四组方法在同一实验协议下可比，本文将输入分成三个层次。第一层是流量统计特征，包括包数、字节数、平均包长、方向比例、到达间隔、TCP 标志和目的端口熵；第二层是窗口事件，包括设备画像、规则命中和历史告警；第三层是语义证据，包括漏洞描述、厂商公告和处置手册。RF、XGBoost 和 1D-CNN 只使用第一层输入；无监督自编码器使用第一层输入和正常样本；RAG-LLM 使用第二、三层输入，并通过检索器访

问带版本号的知识库。这样可以避免大模型因为获得更多原始信息而产生不公平的比较优势。

实验还应报告消融结果。去掉设备画像可以检验模型是否依赖静态身份特征；去掉规则命中可以检验 LLM 是否能够独立关联原始证据；去掉检索库可以测量外部知识的贡献；关闭安全闸门则可以观察提示注入和工具越权的失败率。对于每个消融组，至少记录宏平均 F1、P95 延迟、token 消耗和无证据断言率。

5.3 结果与分析

分类任务报告宏平均 Precision、Recall、F1、AUROC 和每小时误报数；检测系统另报 P95/P99 推理时延、吞吐量、模型大小、峰值内存和单位告警成本。对未见攻击类型，采用留一类攻击外推，并报告检测延迟和证据覆盖率。LLM 的解释质量由两名具有安全背景的评审者依据“事实一致性、证据引用、处置可执行性、风险边界”四项五级量表评分，同时统计无证据断言比例。

推荐使用如下综合指标衡量工程收益：

$$Q = F_1 - \lambda_1 C_{fp} - \lambda_2 T_{p95} - \lambda_3 C_{hall}, \quad (1)$$

其中 C_{fp} 为单位时间误报处置成本， T_{p95} 为 P95 延迟， C_{hall} 为无证据或错误工具调用率， λ_i 由实际部署约束设定。该指标不用于替代原始指标，而用于比较“更准但更慢”和“稍逊但可部署”的方案。

对于类别极不均衡的 IoT 流量，宏平均指标比整体 Accuracy 更能反映少数攻击类别的情况。设第 K 个类别的 Precision 和 Recall 分别为 P_k 和 R_k ，则宏平均 F1 为

$$F_{1,macro} = \frac{1}{K} \sum_{k=1}^K \frac{2P_k R_k}{P_k + R_k}. \quad (2)$$

若系统需要估算运营成本，可进一步将每小时误报数转换为人工分析时间：

$$C_{fp} = N_{fp}^{(h)} t_{triage} c_{analyst}, \quad (3)$$

其中 $N_{fp}^{(h)}$ 为每小时误报数， t_{triage} 为平均单条告警初筛时间， $c_{analyst}$ 为单位时间人工成本。这个定义使模型比较从“谁的准确率更高”转化为“谁在给定预算和时延约束下更可用”。

预期的合理结论不是“大模型在所有指标上最好”，而是：轻量模型负责高频筛选，大模型在跨源关联、解释和响应编排上增加价值；当输入证据不足或检索库过期时，大

模型收益会下降，甚至产生高置信错误。因此最终报告必须同时给出性能、成本和安全失败案例。

5.4 公开论文结果对照

为增加结果的可核验性，本文将公开论文中可直接追溯的实验数字整理如下。需要强调的是，这些结果不是本文在当前环境中重新训练得到的数值，而是对应论文在其数据、特征、划分和硬件条件下报告的结果；本文使用它们进行横向分析，并据此设计后续可复现实验。

表 4 N-BaIoT 与 Kitsune 的公开实验结果

研究	数据与设置	主要结果	对本文的启示
N-BaIoT	9 台商用 IoT 设备; Mirai/BASHLITE; 115 个流量特征; 正常数据训练	TPR=100%; 平均 FPR=0.007 ± 0.01; 平均检测时间=174 ± 212 ms	设备专属基线能降低误报, 但跨设备迁移需要重新校准
Kitsune	9 类网络攻击; 前 100 万包训练; 在线自编码器集成; Raspberry Pi 3B 单核	多数数据集上 AUC/EER 优于在线基线; $k = 1$ 到 $k = 35$ 时吞吐率约由 1000 提升至 5400 包/秒	边缘侧应使用轻量在线模型, 大模型适合后续关联和解释

CICIoT2023 的优势在于攻击覆盖范围和设备规模。该数据集在包含 105 台 IoT 设备的拓扑中执行 33 种攻击，攻击被归并为 DDoS、DoS、Recon、Web-based、Brute Force、Spoofing 和 Mirai 七大类；正常流量采集持续约 16 h，同时提供 pcap 和 csv 两种格式 [5]。论文采用随机打乱后 80%/20% 的训练测试划分，并比较逻辑回归、感知机、AdaBoost、随机森林和 DNN。表5整理了 RF 与 DNN 在三个任务层次上的结果。

表 5 CICIoT2023 原论文中 RF 与 DNN 的结果

任务	模型	Acc.	Recall	Prec.	F1	模型	Acc.	Recall	Prec.	F1
二分类	RF	0.9916	0.8316	0.7045	0.7140	DNN	0.9861	0.7319	0.6653	0.6723
8 类分组	RF	0.9944	0.9100	0.7054	0.7193	DNN	0.9911	0.9066	0.6794	0.6973
34 类细粒度	RF	0.9968	0.9652	0.9654	0.9653	DNN	0.9944	0.9333	0.9476	0.9403

表5 有两个值得注意的现象。第一，准确率始终高于 0.98，但二分类和 8 类分组任务的宏观 F1 明显低于准确率，说明类别不均衡下仅报告准确率会掩盖少数类漏检。第二，原论文采用随机 80%/20% 划分，因而同一设备、同一攻击阶段的相似流量可能同时出现在训练集和测试集；这有利于展示数据集可用性，但不能直接等价为跨时间、跨

设备泛化能力。本文后续实验采用按时间外推和按设备留出的补充划分，正是为了修正这一可比性问题。

综合三篇研究可以得到一个更稳健的结论：N-BaIoT 证明设备行为基线有助于降低 IoT botnet 检测误报，Kitsune 证明在线集成模型可以在低资源边缘设备上运行，CI-CIoT2023 则显示在大规模多攻击分类中 RF 的宏观 F1 仍可能显著低于准确率。因此，大模型若要创造额外价值，应围绕“证据融合、异常解释、跨时间线归因和响应编排”进行评估，而不是只与 RF/DNN 比一个分类准确率。

5.5 Bot-IoT 与顺序检测的详细结果

Bot-IoT 论文的实验同时给出了模型性能和训练成本，这一点对边缘部署尤其重要。表6保留原论文的 Accuracy、Precision、Recall、Fall-out 和训练时间。Fall-out 表示正常样本被误报为攻击的比例，能够补充只看 Accuracy 的不足。

表 6 Bot-IoT 论文中二分类模型的公开结果

模型	特征版本	Accuracy	Precision	Recall	Fall-out	训练时间/s
SVM	10 特征	0.883727	1.000000	0.883712	0.000000	1270.48
SVM	全特征	0.999887	0.999887	1.000000	0.865828	6636.98
RNN	10 特征	0.997405	0.999904	0.997500	0.733753	8035.00
RNN	全特征	0.979061	0.999973	0.979085	0.205451	6888.08
LSTM	10 特征	0.997419	0.999910	0.997508	0.687631	10482.19
LSTM	全特征	0.980573	0.999987	0.980583	0.098532	14073.63

表6中的结果揭示了一个容易被忽略的矛盾：全特征 SVM 的 Recall 达到 1.0，但 Fall-out 也达到 0.8658，意味着模型可能把大量正常流量判为攻击；10 特征 SVM 的 Fall-out 为 0，却牺牲了不少 Recall。对于真实 SOC，二者不能只通过一个 Accuracy 排名。更合理的选择是按照告警预算确定允许的 Fall-out，再在约束下最大化 Recall，这也是本文把每小时误报数纳入评价指标的原因。

顺序检测论文还给出了逐攻击准确率。无特征选择时，J48 在 Ack、Combo、Junk、Scan、Syn、TCP、UDP 和 UDPplain 八类上的准确率分别为 99.01%、99.01%、99.08%、99.05%、99.08%、99.05%、98.99% 和 99.09%；ANN 的对应范围为 98.95%–99.01%。引入特征选择后，NB 的准确率范围提升到 97.34%–99.10%，J48 和 ANN 仍保持在 98.71%–99.10%。在 270908 个测试样本上，顺序混合分类器的串行测试时间为 0.03 s，并行版本为 0.02 s，而单一 ANN 为 9.71 s[9]。这组结果表明，模型级联并不一定带来更高延迟，

关键在于先用特征选择和轻量分类器过滤高置信样本。

5.6 跨论文结果的统一解释

不同论文的数值不能直接放在同一排行榜中。N-BaIoT 和顺序检测研究以设备或攻击类别为中心，Kitsune 关注在线数据包处理率，Bot-IoT 和 CICIoT2023 则更偏向数据集与多分类基准。为了避免错误比较，本文采用“证据类型”而不是“绝对排名”组织结果，如表7所示。

表 7 物联网安全公开论文结果的统一解读

研究	数据规模/划分	指标与结果	可支持的结论	不能直接推出的结论
N-BaIoT	9 台设备；正常流量训练，攻击流量测试	TPR=100%； FPR=0.007 ± 0.01； 174 ± 212 ms	设备专属正常基线对 botnet 异常检测有效	不能证明跨厂商、跨网络环境同样有效
Kitsune	摄像头网络；每个数据集前 100 万包训练	多数场景 AUC/EER 优于在线基线；Pi 3B 约 5400 包/秒	在线集成模型适合低资源边缘设备	不能将吞吐率直接等价为端到端告警时延
Bot-IoT	超过 7200 万条原始记录；10 特征与全特征版本	SVM/RNN/LSTM Accuracy、Recall 高，但 Fall-out 受特征版本影响显著	大规模数据和特征选择会改变模型成本/误报结构	不能仅凭高 Accuracy 断言少数攻击类可靠
顺序检测	N-BaIoT 849234 样本；66%/34% 划分	J48/ANN 逐类约 99%；混合分类测试 0.03 s	级联分类器能降低检测成本	不能与严格时间外推结果直接比较
CICIoT2023	105 台设备；33 种攻击；随机 80%/20%	RF 34 类 F1=0.9653；8 类 F1=0.7193	多类攻击分类可实现，但类别层级显著影响 F1	不能直接代表未知设备泛化能力

表7体现出 一个比“谁的准确率最高”更有价值的研究结论：数据划分、类别粒度和运行约束决定了指标含义。报告中的 LLM 方案应沿用这一原则，分别报告证据关联质量、工具调用安全性、延迟和成本，而不能只给出一个生成文本的主观评分。

六、 综合讨论与工程建议

6.1 从离线指标到线上服务等级

公开论文的结果大多是在离线数据集上产生的，而安全系统最终要面对的是持续到达、资源有限、证据不完整的线上事件。离线 F1 只回答“样本分类是否正确”，线上服务还需要回答“告警是否在攻击造成影响前到达”“同一事件是否被重复告警”“告警是否能够由分析人员复核”和“动作失败后是否可以回滚”。因此，本文建议将指标分成模型层、

表 8 端—边—云协同架构中的功能分工

层级	主要输入	主要功能	安全约束
端侧	原始包、传感器和本地日志	采样、脱敏、轻量规则与特征提取	最小采集、密钥保护、断网可运行
边缘侧	窗口特征、设备画像	RF/XGBoost/1D-CNN 检测、缓存和限流	固定模型、低时延、局部闭环
云侧	告警时间线、资产与情报库	RAG、跨域关联、解释和处置建议	权限隔离、审计、人工审批、可回滚

系统层和运营层三组。模型层报告 Precision、Recall、F1 和 AUROC；系统层报告吞吐率、P95/P99 延迟、内存和能耗；运营层报告每小时告警数、平均初筛时间、证据引用率和人工升级率。

以 N-BaIoT 的 174 ms 平均检测时间为例，这个数字反映从特征输入到异常判断的时间，并不包括抓包、窗口聚合、告警传输和隔离动作。若边缘窗口为 5 s，则端到端响应的下界仍受窗口长度限制。相反，Kitsune 的 5400 包/秒是单核处理能力，不能直接解释为每秒可以完成 5400 次完整调查。报告在引用这些数字时必须说明测量边界，这也是优秀实验报告与简单文献摘录的区别。

6.2 模型选择的决策矩阵

在实际部署中，不同位置的模型选择应由风险、资源和证据需求共同决定。端侧最关心功耗和断网可用性，边缘侧最关心稳定吞吐和固定延迟，云侧最关心跨源关联、解释与更新便利性。表9给出一个可执行的决策矩阵。

表 9 端—边—云模型选择决策矩阵

位置	输入	首选模型	主要指标	失败时的降级策略
端侧	传感器摘要、设备状态	规则、线性模型、小型自编码器	功耗、内存、断网可运行	本地限速、缓存、延迟上报
边缘侧	流窗口、协议统计、设备画像	RF、XGBoost、1D-CNN、在线 AE	吞吐率、P95 延迟、误报预算	固定规则、黑名单、局部隔离
云侧	告警时间线、资产库、漏洞库	RAG-LLM、图分析、人工复核	证据覆盖率、响应时间、工具错误率	禁止自动执行，转人工调查

6.3 如何把大模型纳入可验证闭环

大模型的输出不应直接是自然语言段落，而应先转化为可验证的事件对象。一个最小事件对象包含 `event_id`、`asset_id`、`time_range`、`observations`、`evidence_refs`、`hypotheses`、`confidence` 和 `recommended_actions` 八个字段。模型可以提出多个假设，但每个假设必须绑定证据引用；推荐动作还要包含目标范围、前置条件、风险等级和回滚方法。

在此基础上，系统可以使用规则引擎进行二次验证。例如，当模型建议隔离设备时，验证器检查该设备是否属于关键生产资产、是否存在相邻设备依赖、是否有可用的带外管理通道；当模型建议升级固件时，验证器检查签名、版本兼容性和维护窗口。验证器失败时，系统只保留调查建议，不执行变更。该设计把 LLM 从“自动决策者”降级为“受约束的分析器”，更符合安全工程的责任边界。

6.4 复现与论文写作清单

为了使报告达到可复核标准，最终提交版本应在附录或代码目录中保留以下材料：数据集下载地址和版本、清洗脚本、特征列表、训练/测试划分文件、随机种子、模型超参数、硬件配置、原始指标、错误案例、提示模板、检索文档哈希和日志脱敏规则。对文献结果，应保存论文 DOI、页码或表号；对自行实验，应保存一次完整运行的命令和输出摘要。这样，即使模型或数据集在未来更新，也能定位结果变化来自哪里。

七、挑战与展望

端侧算力与能耗。端侧设备无法承受大模型推理开销，未来需要蒸馏、量化、早退和事件触发式上传，并依据风险动态调整采样率。

数据稀缺与分布偏移。真实攻击样本少且标签昂贵，单一数据集上的高分不代表跨厂商泛化。联邦学习、持续学习和按时间评估可以降低数据集中化风险，但仍需防范投毒和后门。

幻觉、可解释性与证据链。LLM 生成的自然语言解释必须绑定到原始流量、日志、漏洞编号和检索片段。未来应发展带引用约束的生成、可验证工具调用和结构化不确定性表达。

对抗鲁棒性。攻击者可以操纵日志字段、构造提示注入或利用模型对少量特征的敏

感性。系统应进行红队测试、输入校验、提示隔离和模型/规则双通道检测。

隐私合规与责任边界。设备标识、位置和家庭行为数据可能构成敏感信息。应遵循数据最小化、分级留存和可撤回授权原则，并明确模型建议、人工决策和自动执行之间的责任边界。未来的优秀系统应把“能否解释、能否回滚、能否追责”与检测分数同等看待。

八、结论

本文从物联网的分层攻击面出发，建立了安全任务与 AI 范式的二维分类框架，并综述了漏洞挖掘、流量检测、设备识别、威胁情报和安全智能体的代表性方法。综合分析表明，传统模型在高吞吐、低时延判别上仍不可替代，大模型的优势主要体现在跨源证据关联、自然语言解释和受约束的响应编排。面向工程落地，推荐采用“端侧采集与脱敏—边缘侧轻量检测—云侧检索增强分析—人工审批执行”的端—边—云协同模式。

综述报告并未使用未经实验验证的数字包装结论，而是给出了按时间和设备划分数据、统一基线、成本指标和安全失败案例的评估协议。所以仍然需要很多后期工作，尤其关注未见攻击泛化、概念漂移、提示注入和工具越权。只有在证据可追溯、权限可控制、动作可回滚的条件下，大模型才适合作为物联网安全运营的增强组件，而不是新的单点信任根。

A 复现实验记录模板

本附录给出一份可直接用于课程报告复现或后续扩展的记录模板。它把“数据版本、特征处理、模型配置、评价结果和失败案例”放在同一张记录链上，避免只保存最终 Accuracy 而丢失实验条件。实际运行时，应为每次实验生成唯一的 ‘run_id’，并将其写入模型文件、日志文件和结果表。

表 10 复现实验的最小记录字段

记录类别	必填字段	说明
数据版本	数据集名称、下载日期、文件哈希、采集拓扑	记录 CICIoT2023、N-BaIoT 或其他数据的精确版本；若进行脱敏，要记录脱敏规则
划分协议	随机种子、时间边界、留出设备、类别权重	明确是随机划分、时间外推还是设备留出，避免把不同协议的结果混为一谈
特征处理	字段列表、缺失值、归一化参数、窗口大小	归一化参数只能从训练集估计，窗口长度和步长应写入配置文件
模型配置	模型名称、版本、超参数、训练轮数、早停规则	对 LLM 还要记录温度、最大输出长度、系统提示词和工具白名单
知识库	文档来源、版本、分块大小、嵌入模型、检索数量	对 RAG 记录每次检索的文档 ID，保证解释可以回溯
运行环境	CPU、GPU、内存、操作系统、依赖版本	用于解释训练时间、P95 延迟和吞吐率差异
结果与失败	原始混淆矩阵、宏/微平均指标、误报样例、工具错误	除平均指标外，保留至少三个代表性错误案例和对应证据

对于结构化流量特征，建议至少保存以下字段：时间戳、设备哈希、方向、协议、源/目的端口、包数、字节数、平均包长、包长标准差、流持续时间、到达间隔均值与方

差、TCP 标志计数、目的地址数量、DNS 查询类型、TLS 指纹和当前固件版本。字段并非越多越好，关键是能够解释每个字段与攻击行为的关系，并能在隐私要求下完成脱敏。对于高基数地址和设备 ID，可使用不可逆哈希，但要保留同一实验内的一致性。

LLM 实验还应单独保存三类输出：第一类是模型最终回答；第二类是引用的证据片段和文档 ID；第三类是工具调用的结构化参数与执行结果。若只保存第一类文本，就无法判断模型是正确推理、检索到正确知识，还是偶然生成了可信表述。对每个高风险动作，建议额外保存人工审批人、审批时间、动作前置检查和回滚结果。

表 11 建议的错误案例分类

错误类型	判断标准	典型改进措施
漏检	攻击样本被判为正常，且模型没有提出补采建议	增加时间外推、困难样本挖掘和异常阈值校准
误报	正常设备被标记为攻击，且无充分证据	引入设备画像、滑动窗口投票和误报成本约束
归因错误	检测到异常但将攻击类型、设备或时间线判断错误	使用检索证据、关系图和多源交叉验证
证据缺失	回答给出结论但无法指向原始流量、日志或文档	强制结构化引用，缺少证据时输出不确定状态
工具越权	生成的动作超出目标范围或绕过审批	白名单、参数验证、最小权限令牌和回滚机制

参考文献

- [1] National Institute of Standards and Technology. Iot device cybersecurity capability core baseline: NISTIR 8259A[R/OL]. NIST, 2020. DOI: 10.6028/NIST.IR.8259A.
- [2] European Telecommunications Standards Institute. Cyber security for consumer internet of things: Baseline requirements: ETSI EN 303 645 V2.1.1[R]. [S.l.]: ETSI, 2020.
- [3] MEIDAN Y, BOHADANA M, MATHOV Y, et al. N-baiot: Network-based detection of iot botnet attacks using deep autoencoders[J/OL]. IEEE Pervasive Computing, 2018, 17(3):12-22. <https://arxiv.org/abs/1805.03409>. DOI: 10.1109/MPRV.2018.03367731.
- [4] MIRSKY Y, DOITSHMAN T, ELOVICI Y, et al. Kitsune: An ensemble of autoencoders for on-line network intrusion detection[C/OL]//Network and Distributed System Security Symposium. 2018. <https://arxiv.org/abs/1802.09089>. DOI: 10.14722/ndss.2018.23204.
- [5] NETO E, et al. Ciciot2023: A real-time dataset and benchmark for large-scale iot network intrusion detection[J/OL]. Sensors, 2023, 23(13):5941. <https://www.unb.ca/cic/datasets/iotdataset-2023.html>. DOI: 10.3390/s23135941.
- [6] FERRAG M A, et al. Edge-iiotset: A new comprehensive realistic cyber security dataset of iot and iiot applications[J/OL]. IEEE Access, 2022, 10:40281-40306. DOI: 10.1109/ACCESS.2022.3165809.
- [7] LEWIS P, et al. Retrieval-augmented generation for knowledge-intensive nlp tasks[C]//Advances in Neural Information Processing Systems: volume 33. [S.l.: s.n.], 2020: 9459-9474.
- [8] KORONOTIS N, MOUSTAFA N, SITNIKOVA E, et al. Towards the development of realistic botnet dataset in the internet of things for network forensic analytics: Bot-iot dataset[J/OL]. Future Generation Computer Systems, 2019, 100:779-796. <https://arxiv.org/abs/1811.00701>. DOI: 10.1016/j.future.2019.05.041.
- [9] SOE Y N, FENG Y, SANTOSA P I, et al. Machine learning-based iot-botnet attack detection with sequential architecture[J/OL]. Sensors, 2020, 20(16):4372. DOI: 10.3390/s20164372.
- [10] OWASP Foundation. Owasp top 10 for large language model applications[EB/OL]. 2023. <https://owasp.org/www-project-top-10-for-large-language-model-applications/>.